Challenge Writeup

Challenge Name : SQL Injection Login Bypass

Category: Web

Description: Our security team deployed a Web Application Firewall in front of the company login portal. Management is confident that no one can get past it. The admin account has a randomly generated password, so brute-force is not an option. Can you find another way into the admin dashboard

Solution:

Step 1: Initial Analysis

The login form accepts:

- **Username**
- **Password**

A basic SQL injection attempt was made:

admin 'or' 1='1 --

❌ Result:

WAF: Blocked — Possible SQL injection detected!

Step 2: WAF Behavior Testing

To understand the filter, individual components were tested:

Input	Result
'	Allowed
OR	❌ Blocked
or	✅ Allowed
--	❌ Blocked

Key Findings:

- WAF is **case-sensitive**
- Blocks:
  Uppercase OR
  SQL comments (--)
- Allows:
  Lowercase or
  Basic quotes

When we put or in input it gave the output as invalid credentials but in the case of OR it says Possible SQL injection detected.

Step 3: Exploitation Strategy

Since:

- OR is blocked but or is allowed
- Comments (--) are blocked

We must:

- Use **lowercase logical operator**
- Avoid using comments entirely

Step 4: Payload Construction

Working Payload:

admin' or 'a'='a

Step 5: Result

- Successfully logged in as **admin**
- Gained access to the admin dashboard

Flag: ctf7{dont_inject_sql_6c586ebf}